

DCIT 418

Systems and Network Security

EXAMINATION STUDY GUIDE

Chapters 1 to 13

*Based on William Stallings,
Cryptography and Network Security: Principles and Practice, 6th Edition*

University of Ghana | Department of Computer Science

Contents

Contents.....	2
1. The Examination	5
What the format implies.....	5
2. Chapter Map and Weighting.....	6
3. Chapter 1: Overview	7
The CIA triad and its extensions.....	7
The OSI Security Architecture	7
Attack taxonomy.....	7
The six X.800 security services.....	7
Model for network security	7
4. Chapter 2: Classical Encryption Techniques	8
The symmetric cipher model	8
Substitution versus transposition	8
The classical ciphers.....	8
The central lesson of the chapter	8
The one-time pad.....	8
Steganography	8
5. Chapter 3: Block Ciphers and the Data Encryption Standard	10
Block versus stream	10
Shannon’s two principles.....	10
The Feistel structure	10
DES parameters	10
Overall DES structure.....	10
The round function, in order	10
The avalanche effect.....	11
Why DES fell.....	11
The S-box controversy	11
6. Chapter 4: Number Theory and Finite Fields	12
The rule that explains everything downstream.....	12
The algebraic ladder	12
Finite fields.....	12
The AES field	12
7. Chapter 5: The Advanced Encryption Standard.....	13
Origin	13
Parameters.....	13
Structure	13

The four round transformations	13
Two design questions that carry essay marks	13
Key expansion	14
AES against DES.....	14
8. Chapter 6: Block Cipher Operation	15
Multiple encryption and Triple DES	15
The five modes of operation.....	15
Why ECB is unsafe.....	15
The pairs that get confused	15
Why CFB, OFB and CTR decrypt with the encryption function.....	16
XTS-AES	16
9. Chapter 7: Pseudorandom Number Generation and Stream Ciphers	17
Three kinds of generator	17
Randomness against unpredictability.....	17
Stream cipher structure	17
RC4.....	17
RC4 and WEP.....	17
10. Chapter 8: More Number Theory	19
The theorems.....	19
Euler's totient function	19
Primality testing.....	19
Chinese Remainder Theorem in practice.....	19
Discrete logarithms.....	19
11. Chapter 9: Public-Key Cryptography and RSA.....	21
What public-key cryptography solved	21
The two uses of a key pair	21
RSA key generation	21
Encryption and decryption	21
Why decryption recovers the plaintext	21
Why p , q and ϕ of n must stay secret	22
Attacks on RSA and their countermeasures	22
Why public-key has not replaced symmetric cryptography	22
12. Chapter 10: Other Public-Key Cryptosystems.....	23
Diffie-Hellman key exchange	23
The man-in-the-middle attack	23
ElGamal	23
Elliptic curve cryptography	23
Why ECC keys are so much smaller	23

13. Chapter 11: Cryptographic Hash Functions	25
What a hash function is	25
The three security properties	25
The birthday bound	25
The two constructions	25
Digest sizes	26
Applications	26
14. Chapter 12: Message Authentication Codes	27
Why a hash is not enough.....	27
What a MAC is	27
HMAC.....	27
CMAC and authenticated encryption	27
15. Chapter 13: Digital Signatures	29
What a signature provides.....	29
Why the message is hashed before signing.....	29
Why signature security depends on the hash	29
Forgery levels.....	29
The schemes	29
Deterministic against randomised signing.....	30
Certificates and identity.....	30
16. Numerical Constants.....	31
17. Distinctions Most Often Confused.....	32
18. Essay Preparation.....	33
A structure that fits any prompt	33
Likely prompts, with skeletons	33
19. Final Recall Checklist	35

1. The Examination

Sixty minutes on Sakai. The paper carries multiple choice questions, fill-in-the-blanks, and essay questions. Coverage is Chapters 1 to 13 of Stallings together with the course outline. The paper contains no calculation questions.

Indicative structure, based on guidance given in class: approximately fifty multiple choice questions, ten fill-ins, and two longer written questions.

What the format implies

Breadth beats depth. Fifty multiple choice questions spread across thirteen chapters is roughly four per chapter. A chapter known at seventy percent across the board scores better than one chapter mastered and another left blank.

Fill-ins want the exact term. A description earns nothing where the technical word is wanted. Write MixColumns, not “the step that mixes the columns”. Terminology is the single highest-yield thing to drill.

Numbers are written as words. This was stated explicitly in class. If the answer is a number, write it out: sixteen rounds, not 16. It costs nothing and it is an easy mark to lose.

No calculation does not mean no numbers. You will not be asked to compute an RSA key or perform finite field multiplication. You may well be asked how many rounds DES has, what AES’s block size is, or how many S-boxes the DES round function uses. Memorise the constants and skip the arithmetic.

Timing discipline

Multiple choice: roughly thirty seconds each. Flag and move on rather than stalling.

Fill-ins: fast, if the terminology is drilled. Do these second.

Essays: plan a skeleton in one minute, write for eight, check for one.

If an essay is running out of time, write the remaining points as a bullet list. Structure earns partial credit; a blank earns nothing.

2. Chapter Map and Weighting

The course outline formally lists Chapters 1 to 8, with the reading column ending at Chapter 8 in Week 13. The examination was extended in class to cover Chapters 1 to 13. Chapters 11 to 13 are therefore examinable but were not part of the weekly schedule, which usually means they are tested at a conceptual rather than a detailed level.

Ch	Topic	Weight	What is actually tested
1	Overview	High	Attacks, services, mechanisms, CIA triad
2	Classical Encryption	Medium	Cipher types, one-time pad, steganography
3	Block Ciphers and DES	High	Feistel, DES parameters, confusion and diffusion
4	Number Theory and Finite Fields	Medium	Group, ring, field; $GF(p)$ and $GF(2^n)$
5	AES	High	The four transformations, SPN structure, Rijndael
6	Block Cipher Operation	High	Five modes, Triple DES, IV versus counter
7	PRNG and Stream Ciphers	Medium	TRNG/PRNG/CSPRNG, RC4, keystream reuse
8	More Number Theory	Medium	Fermat, Euler, Miller-Rabin, CRT, discrete log
9	Public-Key and RSA	High	Key generation, both formulas, OAEP, timing attack
10	Other Public-Key Systems	Med-High	Diffie-Hellman, MITM, ECC and IoT
11	Hash Functions	Medium	Three properties, birthday bound, sponge
12	Message Authentication Codes	Medium	Hash versus MAC, HMAC, CCM and GCM
13	Digital Signatures	Medium	Non-repudiation, DSA, forgery levels, X.509

3. Chapter 1: Overview

The vocabulary chapter, and therefore the highest marks-per-minute in the book. Almost everything here is a candidate fill-in.

The CIA triad and its extensions

- **Confidentiality** — preventing unauthorised disclosure. Splits into data confidentiality and privacy.
- **Integrity** — preventing unauthorised alteration. Splits into data integrity (the information is unmodified) and system integrity (the system performs as intended, unimpaired).
- **Availability** — systems and data accessible to authorised users on demand. This is what denial of service attacks.

Stallings adds two further objectives beyond the triad: authenticity, meaning the entity is who it claims to be; and non-repudiation, meaning neither party can later deny having sent or received.

The OSI Security Architecture

Three pillars: security attack, security mechanism, security service. Keep the last two apart, because they are a standing exam distractor. The service is what is delivered; the mechanism is how it is delivered.

Encipherment is a mechanism. Authentication is a service.

Attack taxonomy

	Passive	Active
Definition	Observes without altering	Alters data or system state
Types	Release of message contents; traffic analysis	Masquerade; replay; modification of messages; denial of service
Detectable	No — nothing changes	Yes — state changes
Preventable	Yes — by encryption	Not absolutely — the surface is unbounded
Strategy	Prevention	Detection and recovery

Traffic analysis survives encryption. The payload is hidden but source, destination, packet size, timing and frequency remain visible, which is enough to infer who is communicating with whom and how often. This is why padding and traffic shaping exist, and it is a favourite essay point.

The six X.800 security services

Authentication. Access Control. Data Confidentiality. Data Integrity. Non-repudiation. Availability.

The one students drop

Availability is routinely omitted when this list is written from memory. Write all six out by hand until the sixth arrives automatically.

Model for network security

A sender applies a security transformation using a secret, the result crosses an insecure channel where an opponent may be present, and the receiver applies the inverse transformation. A trusted third party sits above the exchange, distributing secret information and arbitrating disputes.

4. Chapter 2: Classical Encryption Techniques

Lower weight, but the substitution-versus-transposition distinction and the one-time pad are reliable exam material.

The symmetric cipher model

Five components: plaintext, encryption algorithm, secret key, ciphertext, decryption algorithm. The key is an input independent of both the plaintext and the algorithm.

Substitution versus transposition

Substitution replaces characters with others. Transposition rearranges their positions without changing the characters themselves. The distinction is not cosmetic: a transposition cipher leaves the letter frequency distribution completely intact, so frequency analysis reveals nothing and the attack targets the permutation instead, typically by anagramming.

The classical ciphers

Cipher	Type	Key point
Caesar	Monoalphabetic substitution	Fixed shift of three
Monoalphabetic	Substitution	Keyspace of 26 factorial, yet broken by frequency analysis
Playfair	Digraph substitution	Five-by-five matrix; I and J share a cell
Vigenère	Polyalphabetic substitution	Repeating keyword flattens frequencies
Vernam / one-time pad	Substitution	The only unconditionally secure cipher
Rail fence	Transposition	Zigzag across rails, read off row by row
Rotor machines	Mechanical polyalphabetic	Very long effective period

The central lesson of the chapter

A monoalphabetic cipher has a keyspace of roughly four times ten to the twenty-six, vastly larger than DES's. It is nonetheless trivially broken, because the mapping is consistent and English letter frequencies pass straight through. Keyspace size bounds only the cost of brute force, and brute force is rarely the best available attack. This point answers several essay prompts.

The one-time pad

Three conditions: the key must be truly random, at least as long as the message, and used only once. Under those conditions every plaintext of that length is equally likely given any ciphertext, so the ciphertext carries zero information. This is perfect secrecy — a mathematical guarantee, not a statement about computational difficulty.

It is impractical because distributing a key as long as the message is exactly as hard as distributing the message. The problem is moved, not solved. Reuse is catastrophic: the exclusive-or of the two ciphertexts cancels the key and yields the exclusive-or of the two plaintexts.

Steganography

Steganography conceals the existence of a message; cryptography conceals its content. They are complementary rather than alternatives, and an encrypted payload can itself be hidden inside a cover file.

5. Chapter 3: Block Ciphers and the Data Encryption Standard

Block versus stream

A block cipher processes a fixed-size group of bits at once. A stream cipher processes one bit or byte at a time, generating a keystream and combining it with the plaintext.

Shannon's two principles

Confusion makes the relationship between the *key* and the ciphertext as complex as possible. Achieved by substitution — S-boxes.

Diffusion spreads the statistical structure of the *plaintext* across the ciphertext. Achieved by permutation.

Which principle pairs with which operation is a standing multiple choice question. Confusion goes with substitution and the key; diffusion goes with permutation and the plaintext.

The Feistel structure

The block is split into two halves. Each round computes:

$$L_i = R_{i-1} \quad R_i = L_{i-1} \oplus F(R_{i-1}, K_i)$$

Why it mattered. Because the change is applied by exclusive-or and only half the block moves, decryption is the same algorithm with the subkeys applied in reverse order. The round function F is never inverted and need not even be invertible, so it can be arbitrarily complex and chosen purely for cryptographic strength. One implementation in hardware or software serves both directions.

Design parameters: block size, key size, number of rounds, subkey generation algorithm, and complexity of the round function.

DES parameters

Parameter	Value
Block size	Sixty-four bits
Stored key size	Sixty-four bits
Parity bits	Eight
Effective key size	Fifty-six bits
Number of rounds	Sixteen
Expansion permutation	Thirty-two bits to forty-eight bits
S-boxes	Eight, each six bits in and four bits out
Subkey length per round	Forty-eight bits

Overall DES structure

Initial permutation, then sixteen Feistel rounds, then a thirty-two-bit swap of the halves, then the inverse initial permutation. The initial and final permutations are fixed, public and key-independent, so they contribute nothing cryptographically. They are believed to have been included for hardware convenience.

The round function, in order

1. Expansion permutation takes the thirty-two-bit right half to forty-eight bits, so it can be combined with the forty-eight-bit subkey.
2. Exclusive-or with the round subkey.
3. Eight S-boxes, each taking six bits and producing four, reducing forty-eight bits back to thirty-two.
4. The P-box permutation, providing diffusion.

Why the S-boxes carry the security

Expansion, permutation and exclusive-or are all linear operations. A cipher built purely from linear steps collapses into a single equivalent linear transformation that can be solved by algebra, no matter how many rounds it has.

The S-boxes are the only non-linear component in DES, and they are therefore the only thing preventing that collapse. All of the cipher's security originates there.

The avalanche effect

A one-bit change in the plaintext or key should flip roughly half the output bits. Without it, related plaintexts produce related ciphertexts, and that correlation is exactly what differential cryptanalysis exploits. It is a deliberate design target, not an accident.

Why DES fell

A fifty-six-bit key admits about seven times ten to the sixteen possibilities, brute-forced by dedicated hardware from the late 1990s. The design was otherwise sound, so keyspace was the binding constraint. The responses were Triple DES as a stopgap and AES as the replacement.

The S-box controversy

The design criteria for the DES S-boxes were classified, which fuelled suspicion that a deliberate weakness had been inserted. Declassification later showed the opposite: the S-boxes had been specifically hardened against differential cryptanalysis, which was not publicly known at the time.

Flagged in class

DES does not shift rows. ShiftRows is an AES transformation. This appears as a multiple choice distractor.

6. Chapter 4: Number Theory and Finite Fields

A support chapter. Since the paper carries no calculations, learn the definitions and the reasons rather than the arithmetic.

The rule that explains everything downstream

The multiplicative inverse of a modulo n exists only when the greatest common divisor of a and n equals one. This single rule explains three separate later requirements: why $GF(p)$ needs p prime, why the $GF(2^n)$ modulus must be irreducible, and why RSA's public exponent must be coprime to ϕ of n .

The algebraic ladder

Structure	Operations	Defining requirement
Group	One	Closure, associativity, identity, inverses
Abelian group	One	A group that is also commutative
Ring	Two	Abelian under addition; multiplication associative and distributive; no multiplicative inverses required
Field	Two	A ring in which every nonzero element has a multiplicative inverse, so division is defined

The ring-to-field boundary is the multiplicative inverse. That is the answer to “what distinguishes a field from a ring”.

Finite fields

$GF(p)$ is a field only when p is prime. Concretely, modulo six the element two has no inverse — two multiplied by one through five never yields one — so the structure is not a field. Modulo seven, every nonzero element has an inverse, because a prime shares no factor with anything below it.

$GF(2^n)$ represents elements as polynomials with binary coefficients, so a byte is read as a polynomial rather than as a number. Addition is exclusive-or, with no carries. Multiplication is polynomial multiplication reduced modulo an irreducible polynomial, irreducible being the polynomial analogue of prime and required for precisely the same reason.

The AES field

AES performs its arithmetic in $GF(2^8)$ with the irreducible polynomial:

$$x^8 + x^4 + x^3 + x + 1$$

Note the terms carefully: eight, four, three, one, then the constant. A common error is writing x squared in place of x to the fourth, or dropping the trailing constant.

Why not simply use integers modulo 256? Because 256 is composite, so every even byte would share the factor two with the modulus and lack an inverse. AES requires invertible transformations, so half the byte values would break the construction. $GF(2^8)$ gives byte-sized arithmetic and a genuine field at the same time.

7. Chapter 5: The Advanced Encryption Standard

Origin

AES was selected by NIST through an open, multi-round public competition, in contrast to DES which was developed internally. The winning algorithm was Rijndael, designed by Joan Daemen and Vincent Rijmen, standardised as FIPS 197. The other finalists were MARS, RC6, Serpent and Twofish. Blowfish was not a finalist, because it predates the competition and uses a sixty-four-bit block.

Parameters

Key size	Rounds	Block size
One hundred and twenty-eight bits	Ten	One hundred and twenty-eight bits
One hundred and ninety-two bits	Twelve	One hundred and twenty-eight bits
Two hundred and fifty-six bits	Fourteen	One hundred and twenty-eight bits

The block size is fixed at one hundred and twenty-eight bits regardless of key size. Only the round count varies.

Structure

AES is not a Feistel cipher. It is a substitution-permutation network. In a Feistel cipher only half the block is transformed per round while the other half passes through unchanged; in AES the entire block is transformed every round. This is the most frequently asked AES question.

The one hundred and twenty-eight-bit block is held in the State, a four-by-four matrix of bytes filled column by column.

The four round transformations

Transformation	What it does	What it provides
SubBytes	Byte-by-byte substitution through a fixed S-box, built from the multiplicative inverse in $GF(2^8)$ followed by an affine transformation	Confusion — the only non-linear step
ShiftRows	Each row cyclically shifted left: row zero by zero, row one by one, row two by two, row three by three	Diffusion across columns
MixColumns	Each column multiplied by a fixed matrix in $GF(2^8)$, so every output byte depends on all four input bytes of that column	Diffusion within a column
AddRoundKey	Exclusive-or of the State with the round subkey	Secrecy — the only key-dependent step

There is an initial AddRoundKey before round one. MixColumns is omitted from the final round.

Two design questions that carry essay marks

Why MixColumns is dropped in the final round. Its diffusion is only useful if further rounds follow to compound it. Including it in the last round would cost computation for no security gain, and would force a pointless inverse step in the decryption algorithm.

Why AddRoundKey alone would not suffice. The other three transformations are fixed and public, so anyone can compute or invert them — they supply mixing but no secrecy. A bare exclusive-or with key material is trivially broken. Security comes from injecting key material between rounds of complex public mixing, so that an attacker who understands the mixing perfectly still cannot proceed without the key.

Key expansion

The cipher key is stretched into one round key per round — eleven in total for AES-128, being one initial plus ten. The g-function applies RotWord, a cyclic one-byte shift of a four-byte word; SubWord, passing each byte through the S-box; and then an exclusive-or with a round constant, Rcon.

Distinct round constants matter. Reusing the same key every round would make the rounds structurally identical and invite slide attacks, which work precisely when a cipher's rounds are indistinguishable.

AES against DES

	DES	AES
Structure	Feistel network	Substitution-permutation network
Block size	Sixty-four bits	One hundred and twenty-eight bits
Key size	Fifty-six bits effective	128, 192 or 256 bits
Rounds	Sixteen	Ten, twelve or fourteen
Decryption	Same algorithm, reversed subkeys	Separate inverse cipher required
Status	Broken by brute force	Current standard

8. Chapter 6: Block Cipher Operation

Multiple encryption and Triple DES

Double DES does not deliver double security, because of the meet-in-the-middle attack. The attacker encrypts the known plaintext under all possible first keys and stores the intermediate values, then decrypts the ciphertext under all possible second keys and looks for a match. This trades memory for time and reduces the work from two to the one hundred and twelve down to roughly two to the fifty-seven, leaving double DES barely stronger than single DES.

Triple DES applies the Encrypt-Decrypt-Encrypt sequence. Two-key Triple DES gives one hundred and twelve effective bits; three-key gives one hundred and sixty-eight. The Encrypt-Decrypt-Encrypt ordering exists so that setting the keys equal reproduces single DES, preserving backward compatibility with deployed equipment.

Triple DES remained a stopgap rather than a permanent fix, because it inherits DES's sixty-four-bit block, which no amount of key lengthening can address, and because it is roughly three times slower than DES.

The five modes of operation

Mode	How the input is formed	Error propagation	Parallel
ECB	Each block encrypted independently	Confined to that block	Yes
CBC	Plaintext exclusive-ored with the previous ciphertext, then encrypted; IV for the first block	That block and the next	Decrypt only
CFB	Keystream from encrypting the previous ciphertext block	That block and the next	Decrypt only
OFB	Keystream from encrypting the previous keystream block	None	No
CTR	Keystream from encrypting an incrementing counter	None	Yes, both ways

Why ECB is unsafe

Each block is encrypted independently with no dependence on position, initialisation vector or any other block. Because the encryption function under a fixed key is deterministic, identical plaintext blocks necessarily produce identical ciphertext blocks. Real data repeats heavily — file headers, padding, uniform image regions, recurring database fields — so the repetition structure of the plaintext is copied faithfully into the ciphertext.

The cipher is not broken and no key is recovered. The information leaks through the pattern of equalities between blocks, which the mode does nothing to conceal. Locating the fault in the mode rather than the cipher is what earns the marks on this question.

The pairs that get confused

CFB against OFB

CFB feeds back the previous ciphertext block. Because the keystream depends on the ciphertext, errors propagate over two blocks.

OFB feeds back the previous keystream block. The keystream never touches the ciphertext, so there is no error propagation — but the chain is strictly serial, which is why OFB cannot be parallelised.

OFB against CTR

Both generate a keystream independently of the ciphertext, so neither propagates errors.

OFB chains keystream to keystream, an inherently serial dependency. CTR derives each block's keystream from an independent counter value known in advance, so any block can be computed immediately and in any order. That is why only CTR parallelises and supports random access.

Initialisation vector against counter

The CBC initialisation vector must be unpredictable. It is exclusive-ored directly with plaintext, so a predictable value lets an attacker who can influence the plaintext mount a chosen-plaintext attack.

The CTR counter need not be unpredictable, but it must be unique. The pairing of key and counter must never repeat, because repetition reuses a keystream and exposes the exclusive-or of two plaintexts.

Why CFB, OFB and CTR decrypt with the encryption function

In all three modes the block cipher is never applied to the plaintext. It is applied only to the initialisation vector, the previous ciphertext, the previous keystream, or a counter, and its sole job is to manufacture a keystream. The plaintext is combined with that keystream by exclusive-or alone. Since exclusive-or is its own inverse, regenerating the same keystream with the same forward operation recovers the plaintext. The decryption function is never needed, and for these modes it need not even be implemented.

XTS-AES

The NIST mode approved in 2010 for block-oriented storage devices such as hard drives and solid-state drives. It uses a tweak derived from the sector or block address alongside the key, so that identical plaintext stored at different disk locations encrypts to different ciphertext. This defeats block shuffling and relocation attacks.

9. Chapter 7: Pseudorandom Number Generation and Stream Ciphers

Three kinds of generator

- **TRNG** — a true random number generator, drawing on a non-deterministic physical process such as thermal noise or clock jitter. Unpredictable, but slow.
- **PRNG** — a deterministic algorithm expanding a seed into a long sequence. Fast and reproducible, and eventually periodic.
- **CSPRNG** — a pseudorandom generator that is additionally computationally unpredictable, so an adversary who has seen part of the output cannot predict the rest.

The standard practical design pairs them: the true generator supplies physical entropy to seed the pseudorandom generator, combining genuine unpredictability with the speed and throughput of an algorithm.

Randomness against unpredictability

Statistical randomness asks whether the output looks random — uniform distribution, no visible correlation. Cryptographic unpredictability asks whether an attacker who has observed many past outputs can predict future ones. Standard test suites check only the first.

The linear congruential generator is the case in point. It is defined by $X_{n+1} = (aX_n + c) \bmod m$, passes statistical tests, and is entirely adequate for simulations. It is cryptographically worthless, because the relation is linear: a handful of consecutive outputs lets an attacker solve for a , c and m and reproduce the entire past and future sequence.

Blum Blum Shub squares modulo a product of two large primes and takes the least significant bit. Its security reduces provably to the hardness of factoring, the same problem underlying RSA. Strong, but slow.

Stream cipher structure

A keystream generator takes the key, and usually an initialisation vector, and produces a keystream. Ciphertext is the plaintext exclusive-ored with the keystream, and decryption is the identical operation.

Keystream reuse

If $C_1 = P_1 \oplus K$ and $C_2 = P_2 \oplus K$, then $C_1 \oplus C_2 = P_1 \oplus P_2$.

The keystream cancels entirely. The attacker obtains the exclusive-or of two plaintexts with no knowledge of the key, and the redundancy of natural language then separates them. This is the same failure as one-time pad reuse.

RC4

Rivest Cipher 4, designed by Ron Rivest in 1987. A stream cipher built from scratch rather than a block cipher in a streaming mode. Two phases:

- **KSA, the Key Scheduling Algorithm** — initialises a state array of two hundred and fifty-six bytes to the values zero through two hundred and fifty-five, then shuffles it into a key-dependent permutation using the secret key.
- **PRGA, the Pseudo-Random Generation Algorithm** — continuously swaps entries in the state array using two index pointers and emits one keystream byte per step.

A useful memory hook: the key scheduling algorithm sets up the shuffled deck; the generation algorithm deals cards from it.

RC4 and WEP

RC4's real-world downfall came through WEP, and the flaw was in how WEP used RC4 rather than in RC4 alone. WEP concatenated a twenty-four-bit initialisation vector with the master key to form the RC4 key. The small initialisation vector space caused rapid reuse, and concatenating predictable values exposed weaknesses in RC4's key schedule — the FMS attack. Statistical biases in RC4's early keystream bytes compounded the problem. RC4 has since been deprecated in favour of AES-based modes.

10. Chapter 8: More Number Theory

The bridge into public-key cryptography. Learn the statements and what each is for.

The theorems

Result	Statement	Condition
Fundamental Theorem of Arithmetic	Every integer greater than one factors into primes in exactly one way	—
Fermat's Little Theorem	a to the power p minus one is congruent to one, modulo p	p must be prime
Euler's Theorem	a to the power ϕ of n is congruent to one, modulo n	Any modulus n , provided a and n are coprime
Prime Number Theorem	Primes occur roughly once every $\ln(n)$ integers near n	—
Chinese Remainder Theorem	A unique solution exists modulo the product of the moduli	The moduli must be pairwise coprime

The distinction that carries a mark. Euler's Theorem generalises Fermat's to any modulus, not only primes; Fermat's is the special case where n is prime, since ϕ of a prime p equals p minus one. RSA's correctness depends on Euler's, because the RSA modulus is composite.

Euler's totient function

ϕ of n counts the positive integers below n that are coprime to n . For a prime p , ϕ of p equals p minus one. For n equal to the product of two distinct primes p and q , ϕ of n equals p minus one multiplied by q minus one. That second formula is the one RSA is built on.

Primality testing

Trial division is infeasible at RSA key sizes, so probabilistic tests are used. Miller-Rabin selects random witnesses and returns either "definitely composite" or "probably prime". The uncertainty is acceptable because the error is one-sided and quantifiable: a composite is never wrongly certified after a failed test, and each additional witness cuts the error probability by at least a factor of four.

The AKS algorithm, published in 2002 by Agrawal, Kayal and Saxena, was the first deterministic, unconditional, polynomial-time primality test.

Chinese Remainder Theorem in practice

Used to accelerate RSA private-key operations. Rather than exponentiating modulo the full n , the holder of p and q computes modulo p and modulo q separately — each with numbers roughly half the bit length — and recombines. The speedup is around fourfold. It does not weaken security, because it requires knowledge of p and q , which only the private key holder possesses.

Discrete logarithms

Given a base g , a prime p , and the value g to the power x modulo p , recovering x is the discrete logarithm problem. Computing forward is cheap by repeated squaring; reversing is infeasible for large p . This asymmetry underlies Diffie-Hellman, ElGamal and DSA.

A primitive root of p is a base whose successive powers modulo p cycle through every nonzero remainder before repeating — it generates the entire multiplicative group.

11. Chapter 9: Public-Key Cryptography and RSA

What public-key cryptography solved

Diffie and Hellman's 1976 breakthrough addressed two problems inherent in purely symmetric cryptography: secure key distribution without a pre-shared secret, and the absence of any scheme equivalent to a handwritten signature.

The mechanism is a trapdoor one-way function — easy to compute forward, infeasible to invert, and easy to invert only with secret extra information. That secret is the private key.

The two uses of a key pair

Goal	Encrypt or sign with	Decrypt or verify with
Confidentiality	The recipient's public key	The recipient's private key
Authentication and non-repudiation	The sender's private key	The sender's public key

For both together, sign first and then encrypt. A message encrypted only with the sender's private key provides authentication but no confidentiality, because anyone holding the public key can read it.

RSA key generation

1. Choose two large distinct primes, p and q .
2. Compute n as the product of p and q .
3. Compute ϕ of n as p minus one multiplied by q minus one.
4. Choose e such that e lies strictly between one and ϕ of n , and the greatest common divisor of e and ϕ of n equals one.
5. Compute d as the multiplicative inverse of e modulo ϕ of n , so that e multiplied by d is congruent to one modulo ϕ of n .

The public key is the pair e and n . The private key is the pair d and n .

Encryption and decryption

$$C = P^e \bmod n$$

$$P = C^d \bmod n$$

The most common RSA error

The modulus in both operations is n , never ϕ of n .

ϕ of n appears only during key generation, where it is the modulus in which e and d are inverses. Work modulo n on the base and modulo ϕ of n on the exponent.

Why decryption recovers the plaintext

Decryption computes C to the power d , which is P to the power e times d . Because d is the inverse of e modulo ϕ of n , the product e times d equals one plus some multiple of ϕ of n . The expression therefore becomes P multiplied by a power of P to the ϕ of n . By Euler's Theorem that factor is congruent to one modulo n , and the whole expression collapses to P .

Fermat's Little Theorem does not apply, because it holds only for a prime modulus and the RSA modulus is composite.

Why p , q and ϕ of n must stay secret

Any one of them yields the private key immediately, since d is simply the inverse of the public e modulo ϕ of n . Worse, knowing n together with ϕ of n recovers p and q outright: their sum is n minus ϕ of n plus one, and their product is n , so they are the roots of a solvable quadratic. Publishing n is safe only because recovering p and q from n alone requires integer factorisation, and that difficulty is the entirety of RSA's security.

Attacks on RSA and their countermeasures

Attack	Mechanism	Countermeasure
Timing attack	Measuring how long decryption takes for different ciphertexts leaks private key bits, because square-and-multiply takes longer when exponent bits are set	Constant-time implementation, or blinding with a random factor
Malleability	Plain RSA satisfies $E(M_1)$ times $E(M_2)$ equals $E(M_1 \text{ times } M_2)$, so a ciphertext can be manipulated by a known factor	OAEP padding
Low exponent	A small e such as three, used without padding, permits a cube-root attack when one message goes to several recipients	OAEP padding, and a larger exponent
Determinism	Plain RSA is deterministic, so identical messages give identical ciphertexts and leak like ECB	OAEP padding

OAEP, Optimal Asymmetric Encryption Padding, randomises the plaintext before encryption, making the scheme probabilistic and non-malleable. It is the standard defence, and it addresses all four issues above.

Why public-key has not replaced symmetric cryptography

Public-key operations rest on modular exponentiation over very large operands and are orders of magnitude slower than symmetric ciphers, which are built from byte substitutions, shifts and exclusive-ors and are hardware-accelerated. RSA is also size-limited and requires padding. Practice therefore uses hybrid encryption: public-key cryptography transports or agrees a session key, and a symmetric cipher carries the bulk data.

12. Chapter 10: Other Public-Key Cryptosystems

Diffie-Hellman key exchange

Diffie-Hellman establishes a shared secret over an insecure channel. It does not encrypt messages.

Two public parameters are known to everyone, including any attacker: a large prime q , and a primitive root α of q . Alice chooses a secret exponent and sends α raised to it modulo q ; Bob does the same. Each then raises the other's public value to their own secret exponent.

Both arrive at α raised to the product of the two secret exponents, because exponentiation commutes. The shared key is never transmitted in any form, and neither private exponent leaves its owner. Security rests on the discrete logarithm problem.

The man-in-the-middle attack

The attacker intercepts each public value in transit and substitutes their own. Alice establishes a shared key with the attacker believing it is with Bob, and Bob does likewise. The attacker decrypts each message with one key, reads it, re-encrypts with the other and forwards it. Both parties see coherent traffic and detect nothing.

The point that earns the marks

No discrete logarithm is ever solved and no cryptographic assumption is violated. The attacker runs two perfectly ordinary, mathematically sound exchanges.

The protocol is bypassed rather than broken, because plain Diffie-Hellman provides no authentication — nothing binds a public value to a verified identity.

The remedy is to authenticate the exchange with digital signatures and public-key certificates.

ElGamal

Built on the same discrete logarithm hardness, but used for encryption rather than key agreement. The sender picks a fresh random value k for each message, and the ciphertext consists of a pair of values. Reusing k across two messages allows an attacker who knows one plaintext to recover the other.

Elliptic curve cryptography

Proposed independently in 1985 by Victor Miller and Neal Koblitz. The curve has the general equation $y^2 = x^3 + ax + b$. For cryptographic use it is defined over a finite field — typically the integers modulo a prime, or $GF(2^m)$ — rather than over the real numbers, so that the set of points is finite, discrete and computable.

The points of the curve, together with a point at infinity that serves as the identity element, form an abelian group under the chord-and-tangent addition rule. Repeated addition of a point to itself is point multiplication.

The hard problem is the Elliptic Curve Discrete Logarithm Problem: given a base point P and the point Q equal to k times P , recover the scalar k .

Why ECC keys are so much smaller

A 256-bit elliptic curve key provides security comparable to a 3072-bit RSA key. The reason is a difference in attack complexity rather than in kind. Integer factorisation admits sub-exponential algorithms, chiefly the general number field sieve, which force RSA moduli to grow rapidly to stay ahead. The elliptic curve discrete logarithm problem admits no known sub-exponential attack on well-chosen curves; the best general methods remain fully exponential.

The practical consequence is smaller keys and signatures to store and transmit, and substantially cheaper arithmetic. This is why ECC is preferred for mobile devices and for constrained environments such as low-power IoT sensors, where memory, bandwidth and battery are all limited.

13. Chapter 11: Cryptographic Hash Functions

What a hash function is

A cryptographic hash function maps input of arbitrary length to a fixed-length output called the message digest. It is deterministic, cheap to compute, unkeyed, and one-way. Because inputs are unbounded and outputs are fixed-length, collisions must exist mathematically, which is why the security properties are stated as computational infeasibility rather than impossibility.

Hashing provides integrity. It does not provide confidentiality, because there is no key and no way back.

The three security properties

Property	Requirement	Protects
Preimage resistance	Given a digest, infeasible to find any input producing it	Stored password hashes
Second preimage resistance	Given a specific input, infeasible to find a different input with the same digest	A named document against substitution
Collision resistance	Infeasible to find any two distinct inputs with the same digest	Digital signatures

Collision resistance is the weakest. Not because the requirement is mild, but because the attacker has the most freedom: both inputs are free, whereas the other two properties fix a target in advance. This is exactly what makes it cheapest to violate.

The birthday bound

The birthday attack exploits the fact that the number of pairs among k inputs grows quadratically, so a collision becomes likely after roughly two to the n over two attempts rather than two to the n . An n -bit digest therefore delivers only about n over two bits of collision security.

The consequence is that a digest must be roughly twice the intended security level. SHA-256 provides one hundred and twenty-eight bits against collisions, which is why it is the modern default, and why MD5's one hundred and twenty-eight-bit digest was never going to survive.

The two constructions

	Merkle-Damgård	Sponge
Used by	MD5, SHA-1, SHA-2	SHA-3 (Keccak)
Method	Iterates a compression function over padded blocks, carrying a chaining value forward	Absorbs input into a large internal state, then squeezes output from it
Length extension	Vulnerable — the digest is the final chaining state	Resistant — the state is larger than the output

The length extension attack works because in Merkle-Damgård the digest is the final internal chaining state. An attacker who knows a digest and the message length can resume the computation and produce a valid digest for the message with data appended, without knowing the original message. The sponge avoids this because only part of its state is squeezed out, so the full state is never revealed.

SHA-3 was selected for structural diversity rather than because SHA-2 was broken. If an advance ever threatened the Merkle-Damgård family, SHA-3 would not fall with it.

Digest sizes

SHA-1 produces one hundred and sixty bits and is retired following practical collisions demonstrated in 2017. SHA-256 produces two hundred and fifty-six bits. SHA-512 produces five hundred and twelve bits. The SHA-2 family also includes SHA-224 and SHA-384.

Applications

Message and file integrity verification; digital signatures; construction of message authentication codes; one-way password file storage; intrusion and virus detection through file fingerprinting; and use in pseudorandom generation.

14. Chapter 12: Message Authentication Codes

Why a hash is not enough

A plain hash is unkeyed, so an attacker on the channel can compute it as easily as the legitimate parties. They alter the message, recompute the digest, and forward both; verification succeeds and the tampering is invisible. A hash detects accidental corruption, because noise cannot recompute a digest, but it offers nothing against a deliberate adversary.

What a MAC is

A message authentication code is a keyed cryptographic checksum: MAC equals C of K and M, where K is a secret key shared by sender and receiver. The receiver recomputes the tag over the received message and compares. A match establishes that the message is unaltered and that it came from someone holding the key.

Service	Provided?	Why
Integrity	Yes	Any alteration changes the tag
Authentication	Yes	Only key holders can produce a valid tag
Confidentiality	No	The message travels in the clear alongside the tag
Non-repudiation	No	The key is shared, so either party could have produced the tag

HMAC

The standard construction, wrapping any cryptographic hash function. The key is padded, exclusive-ored with two distinct constants, and the hash is applied twice in a nested arrangement:

$$\text{HMAC}(K, M) = H((K \oplus \text{opad}) \parallel H((K \oplus \text{ipad}) \parallel M))$$

The two padding constants are ipad, the byte 0x36 repeated, and opad, the byte 0x5C repeated.

Why it nests. The naive construction, hashing the key concatenated with the message, falls to the length extension attack on Merkle-Damgård hashes: an attacker who sees the tag can resume the computation and forge a tag for an extended message without knowing the key. The outer hash conceals the inner chaining state and closes that route. Two distinct constants ensure the inner and outer computations are keyed differently.

HMAC treats the hash as a black box, so it can be built on any hash function, and its security depends on that underlying hash rather than on any block cipher.

CMAC and authenticated encryption

CMAC is the block-cipher-based message authentication code, using a cipher such as AES in a chaining mode with derived subkeys. Its predecessor, the Data Authentication Algorithm, used DES in CBC mode with a zero initialisation vector and had a length-extension weakness for variable-length messages, which CMAC resolves.

Authenticated encryption provides confidentiality and authenticity together in one scheme, avoiding the subtle errors of combining encryption and authentication separately. CCM is Counter with CBC-MAC. GCM is Galois/Counter Mode, pairing counter-mode encryption with GHASH authentication over GF(2 to the one hundred and twenty-eight); GCM is the high-throughput option because GHASH parallelises well in hardware.

A replay attack against a MAC-protected message is countered by including a sequence number or timestamp within the authenticated data, so that the receiver can recognise a stale message.

15. Chapter 13: Digital Signatures

What a signature provides

A digital signature is created with the signer's private key and verified with the corresponding public key. It provides authentication, data integrity, and non-repudiation.

Non-repudiation is the service a message authentication code structurally cannot supply. A MAC's key is shared, so either party could have produced any valid tag and a third party has no basis to attribute it. A signature's private key is held by exactly one party, so only they could have produced it, and anyone can verify this independently. The asymmetry of key possession is the whole of the difference.

Why the message is hashed before signing

Two reasons. First, efficiency and size: signing operations are expensive and operate on values bounded by the modulus or group order, so applying one to a large document directly would be slow and would require splitting it into pieces, which invites reordering and splicing attacks on the individual signatures. Hashing reduces the work to a single operation on a few hundred bits.

Second, indivisibility: one digest commits to the entire document as a single unit, and the avalanche property means any one-bit change anywhere alters the digest completely.

Why signature security depends on the hash

The signature is computed over the digest, not the message, so anything sharing that digest carries the same valid signature. An attacker able to construct a collision can have an innocuous document signed legitimately and then attach that signature to a malicious one, which verifies perfectly. The signing algorithm is never attacked and the private key is never exposed.

A signature scheme's real strength is therefore the minimum of the signing algorithm's strength and the hash function's collision resistance. This is why SHA-1's collision break invalidated signatures built on it, regardless of the signing algorithm underneath.

Forgery levels

Level	What the attacker achieves
Existential forgery	A valid signature on some message, with no control over its content
Selective forgery	A valid signature on a message the attacker chose
Total break	Recovery of the private key, allowing any message to be signed

The schemes

Scheme	Basis	Note
RSA signature	Factoring	RSA with the roles of e and d exchanged; textbook form is deterministic
RSA-PSS	Factoring	Probabilistic Signature Scheme, by Bellare and Rogaway; adds a random salt and structured padding
ElGamal signature	Discrete logarithms	Requires a fresh random value per signature
Schnorr	Discrete logarithms	Valued for efficiency and a simple algebraic structure

Scheme	Basis	Note
DSA / DSS	Discrete logarithms	The NIST standard, FIPS 186; outputs a pair of values and uses a per-message random k
ECDSA	Elliptic curve discrete logarithms	DSA over elliptic curves; equal security with much shorter keys and signatures

Deterministic against randomised signing

Textbook RSA signing is deterministic: the same message always produces the same signature, which leaves it open to existential forgery through the algorithm's multiplicative structure. RSA-PSS, DSA, ECDSA and ElGamal are all randomised, each using a fresh per-message random value.

A consequence worth knowing

In DSA and ECDSA, reusing the per-message random value k across two signatures leaks the private key outright. The randomness is not a refinement; it is load-bearing.

Certificates and identity

A signature proves only that the holder of a particular private key signed. It says nothing about who that holder is. An attacker can generate their own key pair in seconds and sign a fraudulent message; the signature verifies perfectly, because it genuinely was produced by that key pair, but the identity claim is false.

Binding a public key to a real identity requires a digital certificate, issued by a Certificate Authority within a public key infrastructure, in the X.509 format. A chain of trust runs from an end-entity certificate up through intermediate authorities to a self-signed root that the system already trusts. Certificates that must be invalidated before expiry are published in a certificate revocation list.

Note the pattern. This is the same missing property that makes Diffie-Hellman vulnerable to man-in-the-middle. Asymmetric cryptography proves possession of a key, never identity; certificates supply the binding in both contexts.

16. Numerical Constants

No calculation is required, but these constants are standing fill-in material. Remember to write them as words in the answer.

Quantity	Value
DES block size	Sixty-four bits
DES stored key / parity bits / effective key	Sixty-four / eight / fifty-six bits
DES rounds	Sixteen
DES expansion permutation	Thirty-two bits to forty-eight bits
DES S-boxes	Eight, six bits in and four bits out
DES subkey per round	Forty-eight bits
Triple DES, two-key / three-key	One hundred and twelve / one hundred and sixty-eight bits
AES block size	One hundred and twenty-eight bits, always
AES State	Four rows by four columns of bytes
AES key sizes and rounds	128 with ten, 192 with twelve, 256 with fourteen
AES round keys for AES-128	Eleven
AES field and modulus	$GF(2^8)$, with $x^8 + x^4 + x^3 + x + 1$
RC4 state array	Two hundred and fifty-six bytes
WEP initialisation vector	Twenty-four bits
SHA-1 digest	One hundred and sixty bits
SHA-256 / SHA-512 digest	Two hundred and fifty-six / five hundred and twelve bits
Birthday bound	Two to the n over two, for an n-bit digest
HMAC constants	ipad 0x36, opad 0x5C
ECC against RSA	256-bit ECC is comparable to 3072-bit RSA

17. Distinctions Most Often Confused

Multiple choice distractors are built from near-misses. These are the pairs worth separating deliberately before the exam.

Pair	The distinction
Service against mechanism	The service is what is delivered; the mechanism is how. Encipherment is a mechanism
Passive against active	Passive observes without altering and is countered by prevention; active alters state and is countered by detection and recovery
Confusion against diffusion	Confusion obscures the key-to-ciphertext relationship, by substitution; diffusion spreads plaintext statistics, by permutation
Substitution against transposition	Substitution replaces characters; transposition reorders them and leaves frequencies intact
Feistel against SPN	Feistel transforms half the block per round, so F need not be invertible; an SPN transforms the whole block and needs a separate inverse cipher
Ring against field	A field guarantees a multiplicative inverse for every nonzero element; a ring does not
Prime against irreducible	Prime is the integer notion; irreducible is the polynomial analogue. Both guarantee inverses exist
ShiftRows against MixColumns	ShiftRows diffuses across columns and is retained in the final round; MixColumns diffuses within a column and is omitted
ECB against CBC	ECB encrypts each block independently and leaks repetition; CBC chains against the previous ciphertext block
CFB against OFB	CFB feeds back the ciphertext, so errors propagate; OFB feeds back the keystream, so they do not
OFB against CTR	Both avoid error propagation; only CTR parallelises, because its counters are independent
IV against counter	The IV must be unpredictable; the counter must be unique
Fermat against Euler	Fermat's applies to a prime modulus; Euler's to any modulus. RSA needs Euler's
n against phi of n	n is the modulus for values; phi of n is the modulus for exponents and is secret
Factoring against discrete log	Factoring underlies RSA; discrete logarithms underlie Diffie-Hellman, ElGamal and DSA
Preimage against collision	Preimage fixes the target digest; collision leaves both inputs free, which is why it falls first
Merkle-Damgård against sponge	Merkle-Damgård suffers length extension; the sponge does not
Hash against MAC	A hash is unkeyed and gives integrity only; a MAC is keyed and adds authentication
MAC against signature	A MAC uses a shared key and cannot give non-repudiation; a signature uses a private key and can
Encryption against hashing	Encryption is reversible with a key and gives confidentiality; hashing is irreversible and gives integrity

18. Essay Preparation

A sixty-minute paper shared with fifty multiple choice questions and ten fill-ins leaves roughly eight to ten minutes per essay. There is no time to compose a structure on the page, so learn the shapes in advance.

A structure that fits any prompt

1. One sentence answering the question directly.
2. Definitions of the key terms you are about to use.
3. The body — mechanism, comparison, or ordered steps, depending on the verb.
4. A concrete example or consequence.
5. One sentence closing on the question, now earned.

Read the verb. Explain wants a mechanism. Compare wants a structured contrast, ideally a table. Discuss wants both sides and a judgement. Describe wants ordered steps. Answering a compare prompt with a description loses marks even when every fact is correct.

Do not open with throat-clearing. A sentence such as “security is very important in today’s world” earns nothing and costs time. Open by answering.

Likely prompts, with skeletons

Compare passive and active attacks and explain the defensive strategies

Define both. Give the two passive and four active types. Argue the strategic contrast: passive alters nothing so there is no trace to detect, making prevention the only route; active alters state so it is detectable, but the surface is unbounded so detection and recovery dominate. Close on traffic analysis surviving encryption.

Explain the Feistel structure and its significance

State both round equations. Explain reversed-subkey decryption and why exclusive-or makes it work. The significance: F need never be inverted, so it can be arbitrarily complex and one implementation serves both directions. List design parameters. Contrast with AES as a substitution-permutation network, noting what it gains and gives up.

Describe the AES round transformations and the role of each

Name all four in order with what each provides. Explain why MixColumns is omitted from the final round. Then the harder point: the three key-independent transformations supply mixing but no secrecy, AddRoundKey supplies secrecy but is trivial alone, and security comes from the combination.

Compare the five modes of operation

Name all five with their formulas. Tabulate error propagation, stream behaviour and parallelisability. Explain ECB rigorously — locate the fault in the determinism of the mode, not in the cipher. Close by arguing that mode selection matters more in practice than the choice between AES-128 and AES-256, since mode errors succeed against both.

Describe RSA and explain why decryption recovers the plaintext

Five key generation steps. Both formulas, with n named as the modulus. The correctness argument via Euler’s Theorem, noting why Fermat’s does not apply. Close on the secrecy of p , q and ϕ of n , and the factoring assumption.

Describe Diffie-Hellman and the man-in-the-middle attack

Public parameters, each party's actions, and the algebra showing both reach the same value. Then the attack: substitution in each direction, two legitimate exchanges, relaying. The key insight is that no discrete logarithm is solved — the protocol is bypassed because it lacks authentication. Close on certificates as the remedy.

Compare a hash, a MAC and a digital signature

Tabulate keys used, services provided, and who can verify. Explain why only a signature gives non-repudiation, resting on the asymmetry of key possession. Add that signature security depends on the hash's collision resistance.

Discuss the claim that a strong algorithm is not a secure system

Thesis: the algorithm is one component and failures cluster elsewhere. Four illustrations: mode selection, with AES in ECB; parameter reuse, with IVs, counters and keystreams; protocol design, with Diffie-Hellman and man-in-the-middle; and key management, with RSA collapsing if p , q or ϕ of n leaks. Generalise: the attacker takes the cheapest route, which is almost never the cipher.

19. Final Recall Checklist

Answer these closed-book the day before. Anything missed goes on a single sheet of paper, and that sheet — not the book — is what you read in the last hour.

1. The six X.800 security services.
2. The two passive and four active attack types.
3. Both Feistel round equations, with the indices correct.
4. Confusion against diffusion: which is substitution, which is permutation.
5. DES: block size, effective key size, rounds, number of S-boxes and their widths.
6. The one property a field has that a ring may lack.
7. The AES irreducible polynomial, written out in full.
8. The four AES transformations in order, and which is omitted in the final round.
9. Why AES is not a Feistel cipher.
10. The five modes of operation, and which parallelises.
11. OFB feeds back what? CFB feeds back what?
12. The IV requirement against the counter requirement.
13. Triple DES effective key lengths, two-key and three-key.
14. RC4's two phases and its state array size.
15. Euler's Theorem, and why RSA needs it rather than Fermat's.
16. The RSA encryption and decryption formulas, with the modulus named.
17. Both conditions relating e , d and ϕ of n .
18. The hard problem underlying RSA, Diffie-Hellman, and ECC.
19. Why man-in-the-middle defeats Diffie-Hellman without solving a discrete logarithm.
20. How many bits of RSA a 256-bit ECC key is comparable to.
21. The three hash security properties, and which the birthday attack targets.
22. Merkle-Damgård against sponge: which resists length extension.
23. HMAC's two padding constants, and why it nests.
24. What a MAC cannot provide, and why.
25. Which key signs a document, and which verifies it.

Exam-day reminders

Write numbers as words. Sixteen rounds, not 16.

Fill-ins want the exact technical term, not a description.

Watch the standing distractors: AES is not Feistel; DES does not shift rows; the RSA modulus is n , not ϕ of n ; traffic analysis is passive; DSA rests on discrete logarithms; a MAC cannot give non-repudiation.

If an essay is running short on time, write the remaining points as a bullet list. Structure earns partial credit; a blank earns nothing.